LLM-based Understanding of Cloud Incidents from Forensic Evidence Reports

Principal Investigator:	Fabian Monrose, Professor
Affiliation:	ECE, College of Engineering Georgia Institute of Technology
Cash Funding Requested:	$73,653
AWS Promotional Credits Requested:	$21,500

Abstract

Incident responders in cloud environments often lack the visibility needed to determine which system changes are attributable to malware. As a result, teams resort to broad containment or full system rebuilds, leading to unnecessary downtime, cost, and risk of incomplete remediation. We propose LUCID, a practical framework for LLM-guided forensics that enables targeted, evidence-backed remediation. LUCID combines malware behavior analysis with cloud telemetry to generate prioritized actions scoped to the actual impact of an incident. Instead of processing raw logs end-to-end, it uses a hypothesis-driven workflow where an orchestrator formulates candidate explanations of compromise and selectively queries analyst tools to validate them. The design emphasizes (1) selective evidence retrieval to control cost and operate at cloud scale, (2) tool-grounded inference to reduce LLM error by relying on trusted outputs, and (3) auditable reasoning so every recommendation is traceable and reviewable by analysts. By focusing remediation on validated changes rather than broad recovery actions, LUCID reduces operational disruption while improving the speed, precision, and reliability of incident response.

Keywords — Large Language Models, Digital Forensics, Incident Response

A Introduction

Modern cloud incident response often relies on broad containment actions like instance termination, credential rotation, or full re-imaging because precisely identifying the impact of malware is time-consuming and uncertain. This leads to unnecessary downtime and increased analyst workload. The pain points stem from a mismatch between attacker behavior and available evidence. Unlike controlled malware analysis environments, cloud investigations must reconstruct activity from fragmented and sampled telemetry spread across logs, network data, storage snapshots, and configuration histories. Existing approaches typically analyze these sources in isolation or assume complete execution traces, limiting their effectiveness in real-world incidents. At the same time, the scale of cloud telemetry makes naive end-to-end LLM reasoning both costly and error-prone [3, 4].

Our recent work on malware analysis [5] showed that LLMs can recover hidden behaviors when guided by structured workflows like that depected in Figure 1. LUCID will build on this and other insights [7, 8] by adapting these principles to cloud forensics to enable targeted, evidence-backed remediation. However, applying this approach in cloud environments introduces numerous challenges. In particular, the volume and heterogeneity of forensic data mandates that we incrementally and selectively analyze artifacts, rather than ingest all telemetry into a single LLM context.

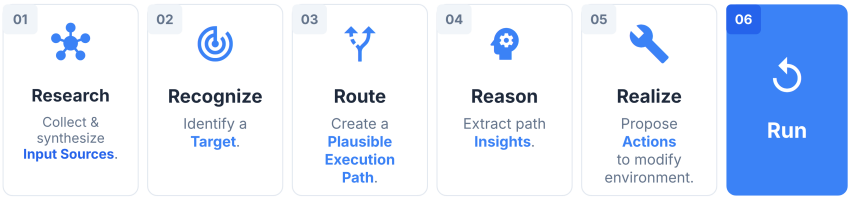


Figure 1: Deterministic steps are used when possible (e.g., provenance graph construction), while LLM components follow a hypothesis-driven process.

To address this, we adopt an orchestrator–worker architecture in which a high-level planner maintains the remediation objective and delegates focused tasks to workers. This structure supports iterative root cause analysis, where relevant evidence is identified and incorporated as the investigation progresses. A key aspect of LUCID is its hypothesis-driven reasoning strategy. Instead of inferring remediation actions from raw telemetry, the system proposes candidate attacker-induced changes (e.g., persistence mechanisms or policy modifications), and gathers evidence to validate or reject each hypothesis using analyst tools.

B Methods

To support the design of a robust end-to-end system, we will explore novel approaches for enabling (1) selective evidence retrieval to control cost and scale to heterogeneous data, (2) tool-grounded reasoning to improve reliability by anchoring inference in trusted outputs, and (3) auditable decision-making so each remediation step is transparent and verifiable. Ideally, the effectiveness of our approach would be judged based on forensic data collected from real-world malware in commercial cloud environments; clearly, the risk of unintended side effects in executing realistic, state-of-the-art malware in such settings is a non-starter. Instead, we plan on conducting evaluations to consider realistic malware and commercial environments separately. Across both settings, our central goal is to measure whether LUCID can (i) correctly identify attacker-induced persistent system modifications from incomplete forensic evidence and (ii) generate remediation actions that neutralize malicious impact without unnecessary collateral disruption.

Table 1: Mapping between malware behavior analysis and cloud remediation workflows.

Aspect	Behavior Analysis	Cloud Remediation
Data Sources	Static and dynamic analysis	Static/dynamic analysis, system logs, and forensic artifacts
Reference Framework	Malware Behavior Catalog	MITRE ATT&CK
Execution Model	Data flow and control flow	Provenance graphs
Key Insights	Execution constraints	Persistent system impact
Response Actions	Sandbox configuration	Targeted system restoration

We will evaluate using a mix of state-of-the-art open- and closed-weight LLMs, as well as older commodity models, in order to measure both absolute system performance and the extent to which LUCID's workflow provides durable gains over naive end-to-end LLM prompting as models evolve. Following recent guidance on LLM evaluation methodology, all comparisons will be cost-controlled [2] and will be designed to limit reward hacking [6]. In addition, we will compare against various, ablated versions of LUCID with individual design choices removed. Our primary evaluation metrics will include: (1) *Recognition recall & precision*, measuring success at correctly identifying code for attacker-induced persistent modifications and (2) *Remediation recall & precision*, measuring the number of correctly neutralized techniques.

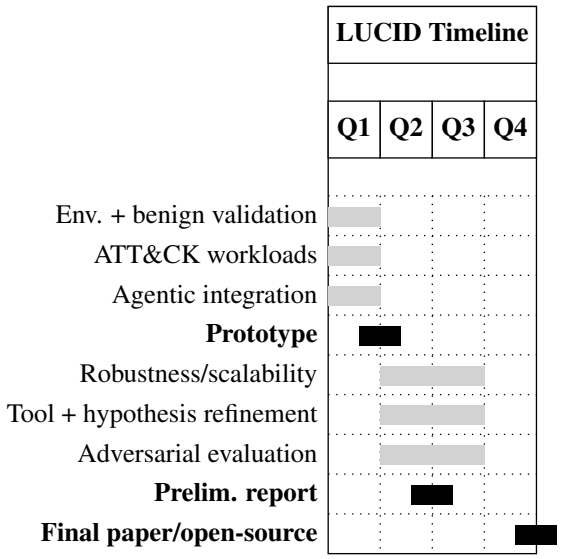
Commercial Cloud Environment with Controlled Adversarial Workloads LUCID will operate over raw evidence collected from cloud-native monitoring, forensic tools, and malware analysis utilities, with the goal of identifying attacker-induced system modifications and producing targeted remediation actions. This setting captures realistic cloud logging conditions, distributed service interactions, and fragmented forensic

evidence. To support that, we will deploy experiments on AWS EC2 instances with simulated sensitive data stored in S3 and logs captured via AWS CloudTrail. We will construct controlled adversarial workloads that implement representative persistent attacker behaviors from the MITRE ATT&CK framework, including data manipulation, persistence, access policy modification, and lateral movement. Benign background activity will be generated using workloads suggested in AWS' tutorials [1] to obscure malicious actions.

Real-World Malware in an Instrumented Cloud-Like Analysis Environment To evaluate LUCID's ability to recover hidden malicious impacts without access to low-level execution details, we plan to replicate the same forensic collection workflow in a sandboxed environment using live malware samples. In this case, LUCID is provided only with externally observable evidence available in the cloud setting, specifically DFIR artifacts and static analysis outputs. And in parallel, we collect full dynamic execution traces to construct ground truth for all attacker-induced system modifications.

C Expected Results

The first quarter focuses on establishing the evaluation environment, including validation on benign cloud workloads and construction of executables implementing MITRE ATT&CK techniques. We will integrate core agentic components for selective access to cloud telemetry and forensic data. The expected outcome is an end-to-end LUCID prototype operating over real cloud artifacts. The second and third quarters focus on improving robustness and scalability, including refining the hypothesis-driven workflow, strengthening tool integration, and evaluating performance across diverse adversarial scenarios. These efforts will produce a stable system and a comprehensive empirical evaluation of LUCID's ability to reconstruct attacker-induced modifications and generate targeted remediation actions. We will release a preliminary report by the end of the second quarter. Final deliverables include a paper submission to a leading systems security venue and open-source release of the LUCID framework and datasets.



D Funds Needed

A significant portion of the requested resources will support use of Amazon Bedrock managed agents. Based on costs observed in our prior experiments with 12 models and a limited set of malware samples [5], we estimate approximately $16,000 for full LUCID evaluations. This estimate is derived from average per-token pricing of frontier models and scaled to the expected workload. We additionally allocate $3,000 for ablation studies in both evaluation settings, focusing on a reduced set of top-performing open- and closed-weight models. These experiments are necessary to isolate the impact of key design components while controlling costs. Cloud infrastructure costs will arise from deploying and evaluating simulated malicious workloads. These include repeated provisioning and teardown of EC2 instances, EBS snapshot collection, and logging via AWS CloudTrail. Due to variability in workload behavior and logging volume, we conservatively allocate $2,500 for these expenses. In total, we request **$21,500 in AWS credits**. We also request **$73,653** to partially support one post-doctoral researcher, supplies, and registration costs for one systems conference.

References

[1] [n. d.]. Hands-on Tutorials. https://aws.amazon.com/getting-started/hands-on/.

[2] Sayash Kapoor, Benedikt Stroebl, Zachary S Siegel, Nitya Nadgir, and Arvind Narayanan. 2024. AI agents that matter. *arXiv preprint arXiv:2407.01502* (2024).

[3] Tianle Li, Ge Zhang, Quy Duc Do, Xiang Yue, and Wenhu Chen. 2025. Long-context LLMs Struggle with Long In-context Learning. *Transactions on Machine Learning Research* (2025).

[4] Nelson F Liu, Kevin Lin, John Hewitt, Ashwin Paranjape, Michele Bevilacqua, Fabio Petroni, and Percy Liang. 2024. Lost in the Middle: How Language Models Use Long Contexts. *Transactions of the Association for Computational Linguistics* (2024).

[5] Kevin Valakuzhy, Miuyin Yong Wong, Doug Blough, Mustaque Ahamad, and Fabian Monrose. 2026. LUMEN: A Systems Approach to LLM-Guided Activation of Hidden Behaviors in Malware. In *56th Annual IEEE/IFIP Conference on Dependable Systems and Networks (DSN)*. to appear.

[6] Zhun Wang, Tianneng Shi, Jingxuan He, Matthew Cai, Jialin Zhang, and Dawn Song. 2025. CyberGym: Evaluating AI Agents' Real-World Cybersecurity Capabilities at Scale. In *International Conference on Learning Representations (ICLR)*.

[7] Miuyin Yong Wong, Matthew Landen, Frank Li, Fabian Monrose, and Mustaque Ahamad. 2024. Comparing Malware Evasion Theory with Practice: Results from Interviews with Expert Analysts. In *Symposium on Usable Privacy and Security, SOUPS*, Patrick Gage Kelley and Apu Kapadia (Eds.). USENIX Association, 61–80.

[8] Miuyin Yong Wong, Kevin Valakuzhy, Mustaque Ahamad, Douglas M. Blough, and Fabian Monrose. 2024. Understanding LLMs Ability to Aid Malware Analysts in Bypassing Evasion Techniques. In *International Conference on Multimodal Interaction, ICMI*. ACM, 36–40.

E CV of PI